# Lab Guide S08: Mô phỏng Tấn công Giả mạo Định danh & Xây dựng Giám sát Phòng thủ

**Mục tiêu:** Thực hành phát hiện lỗ hổng cấu hình cấp phát chứng chỉ tự do và triển khai cơ chế kiểm tra tính hợp lệ của SAN trước khi ký phát hành.

---

## 1. Dựng Máy chủ CA Mô phỏng với Lỗ hổng Cấp phát

Học viên sử dụng kịch bản OpenSSL để mô phỏng một CA thiếu kiểm duyệt trường Subject Alternative Name.

---

## 2. Thực hiện Tấn công Giả mạo SAN

```
# Tạo CSR giả mạo danh tính quản trị viên cấp cao
openssl req -new -nodes -newkey rsa:2048 -keyout evil.key -out evil.csr \
    -subj "/CN=regular-user" \
    -addext "subjectAltName = DNS:admin.internal,DNS:bank.internal"
```

---

## 3. Triển khai Kịch bản Kiểm duyệt Phòng thủ (Pre-issuance Policy Enforcement)

Viết script tự động phân tích CSR trước khi chuyển cho CA ký: * Kiểm tra danh sách SAN: Nếu chứa các tên miền đặc quyền (`admin`, `root`, `bank`) mà người yêu cầu không nằm trong danh sách trắng $ightarrow$ Tự động từ chối và ghi nhật ký cảnh báo bảo mật.

---

## 4. Tiêu chí Đánh giá Bài Lab S08

1. Mô phỏng thành công cuộc tấn công giả mạo SAN.
2. Xây dựng kịch bản phòng thủ chặn đứng thành công yêu cầu cấp phát giả mạo.